



DEFENSA PROYECTO FINAL



- ¿Cómo se podría haber evitado este ataque?



- **1. Prevención contra contraseñas débiles**
- **Medida:** Aplicar una **política de contraseñas seguras**:
 - Requerir mínimo 8 caracteres.
 - Complejidad obligatoria (mayúsculas, números y símbolos).
 - No permitir contraseñas vacías.
- **Resultado:** El ataque con hydra no habría funcionado fácilmente y no se podría explotar `Administrador:admin`.



- **2. Evitar enumeración de usuarios por Kerberos y SMB**
- **Medida:**
 - Configurar el controlador de dominio para **restringir respuestas a peticiones Kerberos sin preautenticación (ASREPRoast)**.
 - Desactivar las **sesiones nulas** de SMB.
- **Resultado:** Herramientas como kerbrute o enum4linux no habrían podido enumerar usuarios ni SID.



- **3. Cierre de puertos innecesarios**
- **Medida:** Filtrar puertos con un **firewall interno** o en el servidor:
 - Bloquear SMB (445), NetBIOS (139), RPC (135) desde IPs no autorizadas.
- **Resultado:** Se evita el uso de `smbexec.py` o acceso remoto mediante `net use`.



- **4. Segmentación de red y control de privilegios**
- **Medida:**
 - Aplicar el **principio de menor privilegio**: usuarios como soporte no deberían ser administradores en Windows 10.
 - Usar cuentas separadas para tareas administrativas.
- **Resultado:** El movimiento lateral no habría sido posible desde el servidor al Windows 10



- **5. Auditoría y monitorización**
- **Medida:** Habilitar auditoría de eventos de inicio de sesión y uso de recursos compartidos.
 - Configurar alertas para accesos remotos sospechosos o uso de cuentas administrativas fuera de horario.
- **Resultado:** Se detectaría actividad anómala a tiempo



- **6. Control de persistencia**
- **Medida:** Revisar y auditar **miembros de grupos de administradores** local y del dominio.
 - Escanear cuentas sin contraseña (backdoor) y eliminarlas.
- **Resultado:** Se evitaría que un atacante dejara un usuario persistente oculto.